

GOLD Token

Altın destekli dijital token projesi

Hiç teknik bilmeyen biri de anlasın diye yazıldı

İki cümleyle bu proje ne?

Bir GOLD = bir gram gerçek altın. Sahip olduğun token'ın karşılığı kasada bekliyor, istediğin zaman satarsın, transfer edersin, 1 kiloyu geçtiğinde de fiziksel olarak teslim alırsın. O kadar.

Not: Burada işin özünü konuşacağız. Detaylı teknik tasarıma ihtiyacın olursa repo içindeki **docs/system-design.md** var, tam 972 satır.

1. Önce hikaye: bu proje neden var?

Diyelim ki elinde bir miktar paran var ve altın almak istiyorsun. Bugün ne yapıyorsun? Ya kuyumcuya gidiyorsun, ya bankaya. Kuyumcuda makas var, bankada saklama ücreti var, ikisinde de fiziksel altını saklamak ayrı bir dert.

GOLD bu işi şöyle yapıyor: kasada gerçek altın çubuklar duruyor, biz bu çubukları senin adına bir miktar 'tahsis' ediyoruz, karşılığında telefonundaki cüzdana 'GOLD' adında bir token geliyor. Bu token bir kağıt parçası değil, gerçek bir gram altına bağlı. Hatta hangi çubuğa bağlı olduğunu seri numarasıyla bile görebilirsin.

Avantajı? Telefondan alıyorsun, telefondan satıyorsun. İstersen arkadaşına gönderiyorsun. Gerçekten elinde tutmak istersen (en az 1 kilo) kargolatiyorsun. Kasa, sigorta, denetim — hepsi arka planda hallediliyor.

Peki PAXG, XAUT zaten var, sen ne farklısın?

Üç şey farklı: **(1)** Onlar 1 ons üzerinden çalışıyor, biz 1 gram. Yani 100 dolarlık altın almak isteyen Türk öğrenci de girebiliyor. **(2)** Onlar tek ülkede, biz dört ülkede lisanslıyız (Türkiye, İsviçre, BAE, Liechtenstein) — bir tanesi kapanırsa diğeri ayakta. **(3)** Onların altını üçüncü taraf rafineriden geliyor, bizim Çorum'da kendi rafinerimiz var. Yani altın bizim, kasa bizim, token bizim. Baştan sona kontrol.

2. Kullanıcı tarafından ne yaşıyor?

En sade haliyle anlatayım. Sen uygulamaya giriyorsun, ben de sistem tarafında ne olduğunu yan yana söyleyeyim:

- **Önce kayıt:** E-posta, telefon, sonra kimlik fotoğrafı + selfie. Türkiye'deyse MERNİS'e bakılıyor, İsviçre'deyse pasaport okunuyor. Bu işlem 'KYC' deniyor — yani 'müşterini tanı'. Bir kere yapıyorsun, bitiyor.
- **Sonra para yatırma:** Banka havalesi, kart, ne kolayına geliyorsa. TL, USD, EUR, AED — hangi arenadansan o para birimi.
- **Sipariş veriyorsun:** 'Bana 50 gram GOLD ver' diyorsun. Sistem o anki altın fiyatını gösteriyor, onaylıyorsun.
- **Arka planda kasaya gidiliyor:** Müsait bir çubuk seçiliyor, 50 gramı senin adına işaretleniyor. Bu kayda 'tahsisat' diyoruz.
- **5 kişiden 3'ü 'tamam' diyor:** Hazine, uyum müdürü, denetçi, teknik, CIO — bunlardan üçü onaylamadan token basılmıyor. Tek kişinin yetkisi yok, kötü niyetli birinin sistemi çalması imkânsız.
- **Token cüzdanına geliyor:** Ethereum üzerinde mint işlemi yapılıyor, 50 GOLD senin cüzdanına düşüyor. Tüm bu süre 2-3 dakika.
- **İstedğini yap:** Sat, gönder, beklet, ya da 1 kiloyu aştığında 'fiziksel istiyorum' de — Brink's ile evine kargolatalım.

Satarken ne oluyor?

Tersini yapıyoruz. Sen 'satıyorum' diyorsun, token cüzdanından alınıp 'yakılıyor' (burn). Yakılma kelimesinden korkma — Ethereum'da bir token'ı sonsuza kadar yok etmek demek bu. Karşılığında kasada o gramlık çubuk tekrar 'boşa çıkıyor' ve sana hesabına paran yatıyor.

3. Sistemin parçaları neler?

Sistemi 4 katmana bölelim. Her birinin işi farklı ama hepsi birbiriyle konuşuyor:

A. Blokzincirdeki akıllı sözleşmeler

Bunlar Ethereum'da çalışan, Solidity diliyle yazılmış kod parçaları. Bir kere yazıldıktan sonra kimse müdahale edemiyor, herkes okuyabiliyor:

- **GoldToken:** Asıl token. Transfer et, bakiye gör, onay ver — temel ERC-20 işleri.
- **ComplianceRegistry:** Kimin alıp satabileceğini tutan defter. KYC yapmamış birine token gitmez.
- **MintController:** Yeni token basımı. Çoklu imza olmadan çalışmaz, denetim 35 günden eskitse de durur.
- **BurnController:** Token yakımı. Satış ya da fiziksel teslim olduğunda devreye girer.
- **ReserveOracle:** Aylık denetim sonucunu blokzincire yazan defter. Bir kez yazıldı mı silinmiyor.
- **PriceOracle:** Chainlink üzerinden anlık altın fiyatı.
- **Treasury Safe:** Sistemin patronu, ama tek patron değil — 5 kişiden 3'ünün imzası gerek.

B. Backend (yani sunucu) servisleri

Blokzincir her şeyi yapamıyor — kimlik doğrulamak, bankayla konuşmak, kasaya komut göndermek gibi işler için klasik sunucu servisleri lazım. Go diliyle yazılmış mikroservisler var, her biri tek bir iş yapıyor:

- **Auth:** Giriş, 2 faktörlü doğrulama, oturum yönetimi.
- **KYC/AML:** Kimliğini doğrular, yaptırım listelerine bakar.
- **Wallet:** Sana saklamalı cüzdan açar ya da kendi cüzdanını bağlatır.
- **Order:** Alış/satış/itfa siparişlerini takip eder.
- **Mint/Burn:** Kasa ile blokzincir arasındaki köprü. En kritik servis.
- **Price Oracle:** Birden fazla kaynaktan altın fiyatı toplar, manipülasyonu yakalar.
- **Proof-of-Reserve:** Aylık denetim verisini toplar, Merkle ağacı kurar, IPFS'e atar.
- **Compliance Engine:** Şüpheli işlemleri tarar, büyük transferlerde 'Travel Rule' uygular.
- **Notification + Reporting:** E-posta/SMS gönderir, devlete rapor üretir.

C. Fiziksel altyapı — kasalar

Bu kısım çoğu kişinin atladığı yer: altın gerçek bir yerde duruyor. Tek kasa yok, dört yerde dağıtık:

Lokasyon	Görev	Arena
Çorum — kendi rafinerimiz	Üretim + birincil kasa	TR
İstanbul — BIST Kıymetli Madenler	Yerel saklama	TR
Zürih — Brink's / Loomis	Avrupa kasası	CH / EU
Dubai — DMCC / Brink's	Körfez kasası	AE

D. Kullanıcının gördüğü kısım

- **Web uygulaması (Next.js):** En tam fonksiyonlu kanal — onboarding, alış/satış, portföy, denetim raporları.
- **iOS ve Android uygulamaları:** Mobil odaklı, native (Swift + Kotlin).
- **Kurumsal API:** Bankaların ve piyasa yapımcıların kullanması için.
- **verify.gold.example:** Halka açık doğrulama portalı. Kimse üye olmadan girip 'şu cüzdanın altını gerçekten var mı' diye sorabilir.

4. Sana neden güveneyim?

İşin can damarı bu soru. Türkiye'de FTX olduğunu görmüş, Celsius olduğunu görmüş bir insan haklı olarak soruyor. Üç katmanlı bir cevabımız var:

Birinci katman: Tahsisli rezerv — kesirli yok

Bankalar genelde 'kesirli rezerv' ile çalışır: 100 lira mevduat topladığında belki 10 lirayı tutar, gerisini kredi olarak verir. Bizde böyle bir şey yok. Sistemde 1.000 token varsa, kasada 1.000 gram altın var. Hangi çubuğun kime ait olduğu da **bar_allocations** diye bir tabloda kayıtlı.

İkinci katman: Aylık Big Four denetimi

Her ayın 1'inde Big Four diye bilinen dört büyük denetim firmasından biri (PwC, Deloitte, EY veya KPMG) dört kasayı fiziksel olarak sayıyor. Her çubuğun seri numarası, ağırlığı, saflığı kayda giriyor.

- Tüm liste 'Merkle ağacı' diye bir veri yapısına sokuluyor — bunun özelliği şu: tek bir çubuk değişse ağacın kökü değişir, anlarsın.
- Denetçi bu kökü EIP-712 standardıyla imzalıyor (sahte imza atılamaz).
- Tam rapor IPFS'e atılıyor — IPFS'in özelliği şu: bir kez yüklendi mi dosya hep aynı 'adres' altında, değiştiremezsin.
- Özet hash blokzincire yazılıyor — geri dönülmez.
- Denetim 35 günden eski olursa MintController yeni token basmayı reddediyor. Yani 'denetim atlayalım' gibi bir oyun yok.

Üçüncü katman: Çubuk bazında doğrulama

Sen verify.gold.example'a cüzdan adresini yazıyorsun. Sistem diyor ki: 'Senin 50 gramın Çorum kasasında, TR-2026-00428 seri numaralı çubukta tahsisli.' Hatta sana Merkle proof veriyor ki, sen bunu blokzincirdeki ReserveOracle sözleşmesinde bağımsız olarak doğrulayabilirsin. Bize güvenmek zorunda bile değilsin — matematik söylüyor.

5. Bunu nasıl yapacağız? — Yol haritası

İlk günden 'her şeyi yapalım' demek tehlikeli. Onun yerine altı faza böldük. Her faz öncekinin üstüne bir özellik ekliyor, hiçbir faz aceleye gelmiyor:

Faz 0 — Temeli atalım (Ay 0-2)

- Ekibi topla: tech lead + 2 smart contract + 2 backend + 1 SRE.
- Ethereum testnet'te ilk kontratları kur — GoldToken, ComplianceRegistry, MintController iskeletleri.
- Yerel geliştirme ortamı (docker-compose ile her şey ayakta) ve CI/CD.
- Güvenlik tehdit modeli atölyesi — neyin nereden saldırı yiyebileceğini konuşalım.
- Tedarikçilerle pilot: Sumsu (KYC), Fireblocks (cüzdan saklama).

Faz 1 — Türkiye MVP'si (Ay 2-6)

- Türkiye için baştan sona iş akışı: kayıt → TL yatırma → mint → cüzdan → satış → TL çekme.
- Tek kasa: Çorum.
- PoR manuel — aylık tablo ve manuel imza yetiyor şimdilik.
- Çalışanlar arası alfa testi (önce kendimiz yiyoruz).
- CMB'ye (Sermaye Piyasası Kurulu) ön başvuru.

Faz 2 — Denetim otomasyonu + İsviçre (Ay 6-10)

- Otomatik PoR: ReserveOracle deploy, Merkle ağacı, IPFS.
- Zürih kasası entegre.
- USD, EUR, CHF para giriş-çıkışı.
- FINMA için SRO başvurusu.
- İlk dış güvenlik denetimi (OpenZeppelin).
- Sepolia testnet'te halka açık beta.

Faz 3 — Mainnet lansmanı (Ay 10-14)

- Ethereum mainnet'e gerçek deploy + Treasury Safe devri.
- İkinci ve üçüncü güvenlik denetimleri (Trail of Bits, Spearbit).
- 10 milyon dolar başlangıç rezervi → ilk mint.
- TR ve CH arenaları canlı.
- 1-2 borsada listeleme + 1 piyasa yapıcı.
- verify.gold.example halka açık.

Faz 4 — Küresele açıl (Ay 14-24)

- Dubai VARA lisansı, BAE arenası.
- Liechtenstein üzerinden MiCA (Avrupa pasaportu).
- Avalanche ve BNB Chain'e LayerZero köprüsü.
- DEX'lerde likidite havuzları.
- Kurumsal API ve banka ortaklıkları.
- Şeriat uyumlu varyant.

Faz 5 — Olgun ürün (Ay 24+)

- Layer 2 (Base, Arbitrum) genişleme.
- Tokenize altın ETF köprüsü.
- Altın leasing / yield ürünleri.
- Açık finansal API (yetkilendirme ile).

6. Hangi teknolojileri seçtik, niye?

Bir kuralımız var: 'hipster' teknoloji yok. Her seçim, 'denetim havuzu geniş mi, operasyonel olarak yorulmaz mıyız' diye sorularak yapıldı:

Katman	Seçim	Niye
Akıllı sözleşme dili	Solidity 0.8.24	En geniş denetim havuzu
Sözleşme framework	Foundry	Hızlı test, modern
Sözleşme kütüphanesi	OpenZeppelin + Solady	Çoktan denetlenmiş
Oracle	Chainlink	PoR desteği en olgun
Köprü (Faz 4)	LayerZero OFT	Merkezi havuz riski yok
Cüzdan saklama	Fireblocks MPC	Policy engine + HSM
Backend dili	Go + TypeScript	Operasyonel olarak basit
Veritabanı	PostgreSQL 16	ACID + zengin özellik
Event bus	NATS JetStream	Hafif, streaming
Web frontend	Next.js 15 + Tailwind	SEO + hız
Mobil	Swift + Kotlin + KMP	Native performans
KYC sağlayıcı	Sumsb + Jumio	İki sağlayıcı, yedek var
Bulut	AWS birincil + GCP yedek	Çoklu region
Container orkestrasyon	Kubernetes (EKS)	Bulut bağımsız

7. Güvenlik — kötü senaryolar ve cevaplarımız

Bir tokenize altın platformunda dört şey aynı anda korunmalı: kod, anahtarlar, fiziksel altın, ve uyum. Birini boş bırakırsak diğerleri işe yaramaz. İşte tehdit bazlı kısa cevaplar:

Olası tehdit	Ne yapıyoruz
Kontratta exploit	Çoklu imza + PoR kontrolü + formal verification + 3 bağımsız denetim
Kasada iç tehdit	4-göz kuralı, CCTV, dual control, çubuk başı etiket
Özel anahtar sızar	AWS CloudHSM L3 + Fireblocks MPC + cold storage
Kullanıcı phishing	Hardware wallet desteği, EIP-712 domain bağlama
Oracle manipülasyonu	Chainlink + 3+ kaynak medyan + sapma koruyucu
Reentrancy (kontrat oyunu)	OpenZeppelin ReentrancyGuard + check-effects-interactions
KYC by-pass (sahte kimlik)	Biyometrik + belge ağı analizi + çift vendor
API'ye DoS atağı	CloudFlare + rate limit + WAF
Bir ülkede regülatör baskını	Diğer üç jurisdiction ayakta, İsviçre yedek
Bağımlılık zinciri (npm/go)	Pinned deps, SBOM, Snyk, iç artifact registry

Pratikte ne anlama geliyor bunlar?

- **Sıcak cüzdan = az miktar:** Toplam altının en fazla %1'i. Günlük işlem için.
- **Soğuk cüzdan = ana hazine:** Çok imzalı, farklı şehirlerde, geofencing alarmlı.
- **Treasury Safe imzacıları:** 5 kişi, 3 farklı şehir, 2 farklı ülke. Hepsi Ledger donanım cüzdanı.
- **Anahtar rotasyonu:** Yılda bir, her olaydan sonra zorunlu.
- **Bug bounty:** Immunefi üzerinden — kritik bug 500 bin USD, yüksek 100 bin USD.
- **Incident response:** Sistem 1 saat içinde geri ayağa kalkmalı (RTO), en fazla 5 dakika veri kaybı (RPO).

8. Kim ne yapacak? — Bařlangıř ekibi

Faz 0 ve 1 iin toplam 13 kiři yetiyor. řiřirilmemiř, herkesin net bir grevi olan bir takım:

Rol	Adet	Ne yapıyor
Tech Lead / Chief Architect	1	Genel mimari, teknik kararlar
Smart Contract Engineer	2	Solidity + Foundry, kontrat tasarımı ve testi
Backend Engineer (Go)	3	Mikroservisler, mint/burn, compliance
Frontend Lead (Next.js)	1	Web uygulaması + verify portalı
Mobile Engineer	2	iOS (Swift) + Android (Kotlin)
SRE / DevOps	1	Kubernetes, CI/CD, gözlemlenebilirlik
Security Engineer	1	Tehdit modeli, audit hazırlığı, key management
QA / Test Engineer	1	E2E testleri, regresyon
Product Manager	1	Sipariř akıřları, KYC akıřları
Compliance Tech Liaison	1	Hukuk ile rn arası kpr

Faz 2 ve sonrası: KYC operasyon, mřteri destek, business development, data analyst, ve  ek arenanın yerel temsilcileri.

9. Hala karara bağlanmamış olanlar

Nisan 2026 toplantısında bazı şeyleri çözdük. Bazıları hâlâ düzenleyici görüşü bekliyor. Şeffaf olalım:

Çözülenler (kesin)

- **Hassasiyet:** 18 decimals — DeFi uyumu ve alt-gram fraksiyon için.
- **Self-custody:** Ülkeye göre değişir — TR'de custodial-only, CH/AE/LI'de Enhanced KYC sonrası serbest.
- **Minimum alım:** 1 gram (sistem üzerinden). DEX'te zaten fraksiyon serbest.
- **Fiziksel teslim minimumu:** 1 kg — LBMA çubuğunu bölmek pahalı.
- **Köprü modeli:** Faz 4'te yeniden değerlendirilecek; şimdilik LayerZero OFT default.

Hala açık olanlar

- **Yakım onayı:** 100 gramın altı otomatik mi, üstü onaylı mı? Henüz karar yok.
- **KVKK veri ikametgâhı:** Türk kullanıcı verisi yurt dışına çıkabilir mi? Hukuki görüş bekliyoruz.
- **Gas ödeme:** Kullanıcı ETH mi ödesin, biz mi ödeyelim (meta-tx)? v1'de EIP-2612 permit, v2'de paymaster planı var.
- **Layer 2 stratejisi:** Day-1 sadece Ethereum mi, yoksa Base/Arbitrum day-1 mi? Öneri: önce mainnet, sonra L2.

10. Tek sayfada özet

GOLD nedir?

Her token tam olarak bir gram altın. Dört ülkede lisanslı, ayda bir Big Four tarafından denetlenen, kendi rafinerisi olan bir dijital altın platformu.

Nasıl çalışıyor?

Sen para yatırırısın → kasadaki çubuğun bir kısmı sana tahsis edilir → 5 imzadan 3'ü tamam derse token cüzdanına gelir. Satarken tersi: token yakılır, çubuk boşa çıkar, paran hesabına döner.

Rakiplerden farkı?

1 gram minimum (1 ons değil), dört yetki alanı (TR/CH/AE/LI), kendi rafinerimiz, çubuk bazında izlenebilirlik, Merkle proof ile bağımsız doğrulama.

Nasıl yapılacak?

Altı fazlı, 24+ aylık plan. Önce Türkiye MVP, sonra İsviçre + otomatik denetim, sonra mainnet lansmanı, sonra global ölçek ve olgun ürün. Hiçbir adım atlanmıyor.

Ne kadar sürer, ne kadar tutar?

İlk MVP (TR arena, manuel denetim): 6 ay. Mainnet lansman (otomatik PoR + 3 güvenlik denetimi): 14 ay. Tam global ölçek (4 arena + çoklu zincir): 24+ ay. Başlangıç rezervi: 10 milyon USD. Başlangıç ekibi 13 kişi.

Detaya inmek istersen: **docs/system-design.md** (972 satır tam mimari), **docs/contracts/README.md** (kontrat spec), **docs/backend/README.md** (backend spec).